

UK GDPR and Data Protection Law for AI

WHY THIS MODULE MATTERS

Almost every AI system processes personal data, and in the UK that means the UK GDPR applies whether or not anyone in the room is a lawyer. This module gives you the practical fluency to spot the compliance questions before a regulator does.

6.1 Why Data Protection Law Matters for AI

Almost every consequential AI system processes personal data — whether as training data, as an input at the point of decision, or as an output about an identifiable person. In the UK, that processing is governed by the UK GDPR (the retained, UK-specific version of the EU General Data Protection Regulation) and the Data Protection Act 2018, both regulated by the Information Commissioner's Office (ICO). This module sets out the core obligations and how they apply specifically to AI systems.

6.2 The Seven UK GDPR Principles

Article 5 of the UK GDPR sets out seven principles that apply to all processing of personal data, including data used to train, test or operate an AI system.



Figure 6.1 — The seven UK GDPR Article 5 principles.

- **Lawfulness, fairness and transparency** — processing must have a valid lawful basis and be conducted in ways people would reasonably expect.
- **Purpose limitation** — data collected for one purpose should not be silently repurposed to train an unrelated AI system.
- **Data minimisation** — only the data genuinely necessary for the stated purpose should be collected and used, including in training datasets.
- **Accuracy** — personal data must be accurate and kept up to date, which is a genuine challenge for models trained on historical data that may no longer reflect current facts.
- **Storage limitation** — personal data, including data embedded in training sets, should not be kept for longer than necessary.

- **Integrity and confidentiality** — appropriate security must protect personal data against unauthorised access, loss or damage.
- **Accountability** — organisations must be able to demonstrate compliance with all of the above, not simply assert it.

6.3 Lawful Bases for Processing

Every use of personal data in an AI system needs a lawful basis under Article 6 of the UK GDPR. Six bases are available, and the right one depends on the context — there is no single basis that applies to all AI processing.

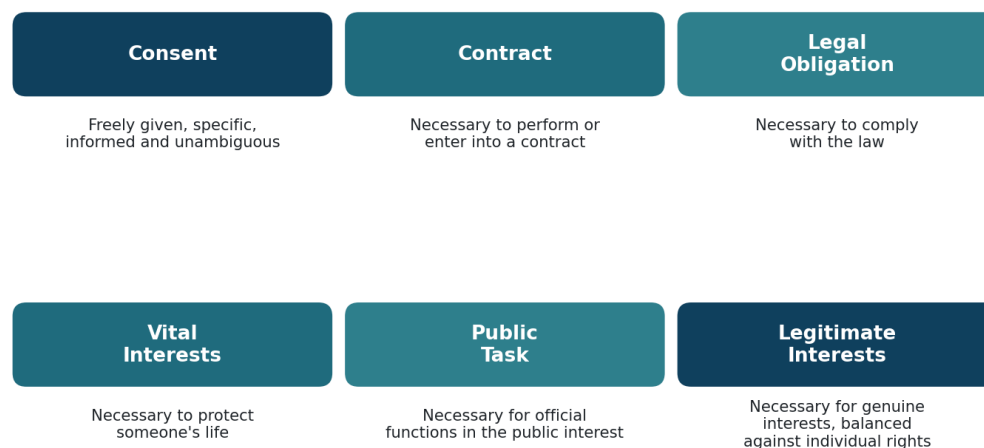


Figure 6.2 — The six lawful bases for processing personal data under Article 6.

In practice, most AI development and deployment in a commercial context relies on either consent or legitimate interests, with public sector AI more often relying on public task. Special category data — revealing race, health, religion, sexual orientation and similar characteristics, defined in Article 9 — requires an additional condition on top of an Article 6 basis, and is particularly relevant when testing an AI system for fairness across protected groups, since that testing itself involves processing special category data.

6.4 Automated Decision-Making and Article 22

Article 22 of the UK GDPR gives people a right not to be subject to a decision based solely on automated processing, including profiling, where that decision produces legal effects concerning them or similarly significantly affects them — for example, automated credit refusals or automated CV rejection with no human

involvement. Where such processing is permitted (because it is necessary for a contract, authorised by law, or based on explicit consent), organisations must still provide safeguards: the right to obtain human intervention, the right to express a point of view, and the right to contest the decision.

UK IN FOCUS

The Data (Use and Access) Act 2025 (DUAA) made the first amendments to the UK GDPR since it took effect, with most data protection provisions in force from early 2026. Two changes are especially relevant to AI: the Article 22 restriction on solely automated decision-making now applies specifically where special category data is involved and there is no meaningful human involvement, and organisations can rely on legitimate interests as a lawful basis for automated decision-making that does not involve special category data, provided safeguards are in place. The DUAA also renames the ICO the “Information Commission”, introduces a right for individuals to complain directly to controllers with a duty to acknowledge within 30 days, and replaces the old “adequacy” test for international transfers with a new “data protection test”. Always check current ICO guidance, as commencement of these provisions is phased through 2026.

6.5 Data Protection Impact Assessments (DPIAs)

A DPIA is a structured process for identifying and minimising data protection risks in a project, and UK GDPR Article 35 makes one mandatory before starting any processing that is likely to result in a high risk to individuals. The ICO explicitly names large-scale profiling, systematic automated decision-making with legal or similarly significant effects, and innovative uses of new technology as triggers — which captures most consequential AI systems.



Data Protection Impact Assessment (DPIA) — high-risk AI processing

Figure 6.3 — The core stages of a Data Protection Impact Assessment.

IN PRACTICE

A medium-sized NHS trust plans to introduce an AI tool to optimise appointment scheduling. Before deployment, it completes an AI inventory entry, conducts a DPIA given the scale of patient data involved, assigns a named accountable owner, and establishes a monitoring routine to check the tool is not systematically deprioritising any patient group. None of this delays the go-live date by more than a few days, because it runs alongside procurement rather than after it.

TRY THIS — YOU ARE THE DATA PROTECTION LEAD

Scenario: the marketing team wants to build a customer service chatbot by fine-tuning a language model on two years of past customer service transcripts, which include names, email addresses, order histories and occasional health-related comments (customers explaining a delayed delivery affected a medical appointment, for example). Marketing argues this is “just reusing data we already have” and wants to launch within a month. As Data Protection Lead, what do you require before this proceeds? (Model answer: this is very unlikely to be a simple reuse. The original transcripts were collected for customer service, not model training, which raises a purpose-limitation question under section 6.2; the health-related comments are special category data requiring an Article 9 condition; the scale and novelty of the processing make a DPIA all but mandatory; and personal identifiers should be removed or pseudonymised wherever the model's performance does not genuinely depend on them, per Article 25. None of this rules the project out — it means DPIA, data minimisation and a documented lawful basis come before launch, not after.)

6.6 Data Protection by Design and Default

Article 25 requires organisations to build data protection into a system from the outset, rather than adding it afterwards — the same lifecycle logic introduced in Module 2 for ethics generally. For AI systems, this typically means minimising personal data in training sets wherever a model's performance does not genuinely depend on it, applying pseudonymisation or anonymisation where feasible, and defaulting to the most privacy-protective configuration a system offers.

International Transfers and Third-Party AI Providers

Many organisations use AI tools or cloud infrastructure hosted outside the UK. Transferring personal data to a third country requires either a UK adequacy regulation covering that country, or an appropriate safeguard such as the UK's International Data Transfer Agreement or Addendum. This is a frequent compliance gap when adopting third-party AI tools quickly, particularly generative AI services where prompts or documents containing personal data may be sent to servers overseas.

IN PRACTICE

An NHS trust wants to trial an AI triage tool that flags high-risk patients from referral letters. Before processing any patient data, the trust must identify a lawful basis (likely public task, with an Article 9 condition for the health data involved), complete a DPIA given the scale and sensitivity of processing, confirm where the vendor hosts and processes data, and ensure a clinician — not the algorithm alone — makes the final triage decision, satisfying Article 22 as well as clinical safety requirements.

6.7 Data Residency and the Physical Data Centre

This module has, until now, treated data protection as a question of process. It is also a question of geography. Where personal data physically sits — which building, which country, which rack — determines which transfer rules in section 6.6 apply, and is frequently a specific contractual requirement from clients in regulated sectors such as financial services, healthcare and government, who may require data to remain within the UK regardless of what the law strictly permits. This makes the data centre itself a site of direct data protection compliance, not merely a neutral host for it.

- **CCTV and access logs are personal data** — footage and swipe/biometric access records covering staff and visitors inside a UK data centre are themselves subject to the UK GDPR, including the accuracy, storage limitation and security principles from section 6.2, and are commonly overlooked in an organisation's own data mapping.
- **Biometric access data is special category data** — fingerprint, iris or facial recognition templates used for staff access control fall under Article 9 and need an explicit condition, most often explicit consent or substantial public interest with an appropriate policy document.
- **Sovereign and client-mandated residency** — “data sovereignty” requirements, where a client insists AI training or inference data never leaves UK soil, go beyond the legal minimum under the international transfer rules and should be captured as an explicit contractual and technical control, not assumed from the data centre's location alone.
- **Colocation and multi-tenant considerations** — where an operator hosts several clients' AI infrastructure in one facility, logical and physical separation controls themselves become part of the “integrity and confidentiality” principle for each client's data.

CASE STUDY — THE ICO AND CLEARVIEW AI

Clearview AI built a facial recognition database by scraping billions of images from social media and other public websites without the knowledge or consent of the people pictured, then sold search access to law enforcement and other bodies. In May 2022, the ICO fined Clearview AI more than £7.5 million and ordered it to delete the data of UK residents, finding that the company had failed to use the images fairly or transparently, had no lawful basis for collecting the highly sensitive biometric data involved, and had no process for people to object or have their images removed.

The case is a direct illustration of the biometric data point above: facial recognition templates are special category data, and “the data was publicly available online” is not, by itself, a lawful basis for scraping and processing it at scale.

TRY THIS — SPOT THE DPIA TRIGGER

Which of the following would most likely require a mandatory DPIA before launch: (a) an internal tool that formats meeting notes using a language model, with no personal data involved; (b) a new biometric access control system replacing keycards at a data centre; (c) a spreadsheet macro that colour-codes overdue invoices? (Answer: (b) — biometric identification is explicitly named by the ICO as a DPIA trigger and involves special category data; neither (a) nor (c) involves the kind of large-scale or high-risk processing that triggers the requirement.)

KEY TAKEAWAYS

- UK GDPR Article 5 sets out seven principles that apply to all personal data used in AI systems, including training data.
- Every use of personal data needs a lawful basis under Article 6; special category data needs an additional Article 9 condition.
- The ICO’s £7.5 million fine against Clearview AI shows that “publicly available data” is not, by itself, a lawful basis for large-scale biometric processing.
- Article 22 restricts solely automated decisions with legal or similarly significant effects, and the DUAA 2025 has narrowed and clarified this restriction, particularly around special category data and legitimate interests.
- A DPIA is mandatory before deploying most high-risk AI systems, and should be started early, not retrofitted before launch.
- CCTV footage and biometric access logs inside a data centre are personal, often special category, data in their own right — not just the client workloads the building hosts.
- Data protection by design, and clarity on where a third-party AI provider or data centre physically processes data, are recurring compliance gaps in real deployments.

FURTHER READING

- ICO — Guide to UK GDPR, ico.org.uk
- ICO — guidance on Data Protection Impact Assessments
- gov.uk — Data (Use and Access) Act 2025, legislation.gov.uk

MODULE 6 CHECK-IN QUIZ

Five questions to confirm your understanding before moving on. Answers are provided in the Answer Key at the end of the course.

1. Which UK GDPR Article 5 principle requires that personal data not be kept for longer than necessary, including within training datasets?

- A. Purpose limitation
- B. Storage limitation
- C. Data minimisation
- D. Accountability

2. Under Article 6 of the UK GDPR, how many lawful bases are available for processing personal data?

- A. Three
- B. Four
- C. Six
- D. Ten

3. What additional requirement applies when processing special category data, such as data revealing health or ethnicity, for fairness testing of an AI system?

- A. No additional requirement applies
- B. An additional Article 9 condition is required on top of an Article 6 lawful basis
- C. Special category data cannot lawfully be processed under any circumstances
- D. Only consent may ever be used

4. What safeguards must be offered when a decision is based solely on automated processing and has a legal or similarly significant effect, where such processing is permitted?

- A. No safeguards are required
- B. The right to obtain human intervention, express a view, and contest the decision
- C. Only a right to a refund
- D. Only a right to delete the underlying data

5. According to Module 6, what change did the Data (Use and Access) Act 2025 make regarding legitimate interests as a lawful basis?

- A. It abolished legitimate interests as a lawful basis entirely
- B. It allowed legitimate interests to be used for some automated decision-making not involving special category data, subject to safeguards
- C. It made legitimate interests the only lawful basis available for AI
- D. It had no effect on automated decision-making